

API Security Assessment

Assessment Overview

An API security assessment was conducted to evaluate the robustness of application programming interfaces against common vulnerabilities outlined in the **OWASP API Security Top 10**. Testing was performed in a controlled laboratory environment using a deliberately vulnerable DVWA-based API to simulate real-world attack scenarios.

Scope and Methodology

Tools Used

- Burp Suite
- Postman
- sqlmap

Testing Methodology

The assessment combined automated and manual testing techniques to identify authorization flaws, input validation issues, and query manipulation vulnerabilities. Emphasis was placed on access control enforcement and API-specific attack vectors.

Identified Vulnerabilities

Test ID	Vulnerability	Severity	Affected Endpoint
008	Broken Object Level Authorization (BOLA)	Critical	/api/users
009	GraphQL Injection	High	/graphql

Technical Findings

Broken Object Level Authorization (BOLA)

The /api/users endpoint failed to enforce proper object-level authorization. By manipulating API tokens and request parameters using Burp Suite, unauthorized access to sensitive user data was achieved, indicating insufficient access control validation on backend resources.

GraphQL Injection

The GraphQL endpoint was vulnerable to injection attacks due to improper query validation. Fuzzing of GraphQL queries and mutations via Postman revealed the ability to manipulate backend queries, potentially leading to unauthorized data exposure and service abuse.

Impact Assessment

Successful exploitation of the identified vulnerabilities could allow attackers to access or manipulate sensitive data, bypass authorization controls, and compromise application integrity. These issues pose a significant risk, particularly in production environments exposing APIs to untrusted clients.

Recommendations

- Enforce strict object-level authorization checks for all API endpoints
 - Validate user permissions on every request, independent of client-side controls
 - Implement robust input validation and query whitelisting for GraphQL APIs
 - Apply rate limiting and detailed logging to detect anomalous API usage
 - Conduct regular API security testing aligned with OWASP guidelines
-

Conclusion

The API security assessment identified critical authorization and injection weaknesses within the tested environment. Addressing these findings is essential to prevent unauthorized data access and ensure secure API operation. Remediation efforts should be verified through follow-up testing to confirm effectiveness.

API Security Testing Summary

API security testing identified critical authorization and injection vulnerabilities within a DVWA-based API. Broken Object Level Authorization enabled unauthorized data access, while GraphQL injection exposed backend query manipulation risks. Findings highlight the need for strict access controls, input validation, and regular API security assessments.